# CIA Part 1 – Questions 296–354

## Impossible-Level: Judgment, Nuance, Standards Priority

CIA Study Prep

October 17, 2026

# Instructions

Each question slide is followed by a separate answer/explanation slide.

Every option is defensible; the correct answer turns on a Standards priority or a single word.

Read every qualifier (MOST, LEAST, FIRST, BEST, PRIMARY) before answering.

Do not advance until you have committed to an answer.

# Q296

**Question:** A CAE reports functionally to the audit committee and administratively to the CFO. The CFO is the subject of an anonymous hotline allegation of expense fraud. The CAE's staff is small; the only auditor with fraud experience is the CAE. The audit committee chair asks the CAE to "handle it internally." Which is the MOST appropriate FIRST action?

A. Conduct the investigation personally because the CAE is the only experienced fraud auditor.

B. Recognize the self-review/independence conflict (CFO is administrative reporting line and subject), document it, and escalate the matter to the audit committee with a recommendation for an independent investigator.

C. Refer the matter to the external auditor and close the complaint.

D. Ask the CFO for an explanation before deciding whether to investigate.

# Q296 – Answer & Explanation

**Correct Answer: B**

**Why:** The CAE is administratively dependent on the CFO and the CFO is the subject, creating a significant objectivity/independence threat. The FIRST step is to document and escalate to the audit committee with a recommendation for an independent investigator (Standards 1110/1130/1210.A2).

**A wrong:** The CAE investigating his own administrative superior is a self-review/conflict threat.

**C wrong:** Closing the complaint without investigation is improper.

**D wrong:** Asking the subject first tips off the investigation and compromises evidence.

# Q297

**Question:** An auditor is testing revenue at a company that sells equipment and separately sells a five-year service contract. The company recognizes the full equipment revenue at shipment and the service revenue at contract signing. The service contract includes a "cancellation for convenience" right with a full refund of unused service fees. Which is the MOST appropriate conclusion?

A. Revenue recognition is appropriate for both equipment and service.

B. Equipment revenue may be appropriate, but service revenue is likely overstated; a cancellation-for-convenience right with refund means service revenue should be recognized over time as services are provided.

C. Both revenues are overstated because the customer can cancel.

D. Revenue recognition is appropriate because the contract is signed.

# Q297 – Answer & Explanation

**Correct Answer: B**

**Why:** Equipment delivered at shipment may be recognized if control transferred; but service revenue with a cancellation-for-convenience right and refund cannot be recognized at signing — it must be recognized over time as services are provided. The question tests separating the two performance obligations.

**A wrong:** Service revenue timing is wrong.

**C wrong:** Equipment revenue may be fine; the issue is service revenue.

**D wrong:** Signature does not determine timing.

# Q298

**Question:** The CAE is conducting the annual conformance assessment. Findings: (1) the charter is board-approved; (2) the plan is risk-based; (3) an engagement audited the CAE's own prior department within 6 months of the CAE's transfer; (4) the last external assessment was 4 years ago; (5) the QAIP includes ongoing and periodic internal assessments. The CAE wants to conclude "generally conforms." Which finding MOST directly prevents that conclusion?

A. The engagement of the CAE's prior department within 6 months.

B. The external assessment being 4 years ago.

C. The risk-based plan.

D. The QAIP internal assessments.

# Q298 – Answer & Explanation

**Correct Answer: A**

**Why:** Standard 1130.A1/1130.A2 prohibits auditing a function the auditor managed within the prior year (self-review). Auditing the CAE's own prior department within 6 months is a direct objectivity impairment — the most serious nonconformance among the options. The 4-year-old external assessment is still within the 5-year window, so it is not a nonconformance.

**B wrong:** 4 years is within the 5-year requirement.

**C wrong:** Risk-based plan is a strength.

**D wrong:** Internal assessments are a strength.

# Q299

**Question:** An auditor is evaluating the organization's third-party risk management for a critical SaaS provider. The provider has a SOC 2 Type II report with no exceptions, but the report is 18 months old, the provider has since been acquired by a private equity firm, and the provider's subservice providers are not listed in the report. The organization has no audit rights. Which is the MOST appropriate conclusion?

A. Reliance is reasonable because the report is Type II with no exceptions.

B. Reliance is significantly limited; the report is stale, ownership changed, subservice providers are undisclosed, and audit rights are absent — creating material third-party risk requiring mitigation.

C. The organization should terminate the provider immediately.

D. SOC reports are irrelevant to SaaS providers.

# Q299 – Answer & Explanation

**Correct Answer: B**

**Why:** Multiple factors (staleness, ownership change, undisclosed subservice providers, no audit rights) together significantly limit reliance. Each one alone might be manageable; together they create material risk.

**A wrong:** Type II with no exceptions does not cure staleness/ownership/subservice gaps.

**C wrong:** Termination is an overreaction; mitigation/updated assurance is appropriate.

**D wrong:** SOC reports are relevant to SaaS.

# Q300

**Question:** An auditor finds that the controller has the ability to post manual journal entries and then "hide" them from the standard ledger view. The controller used this 9 times; all entries increased revenue, reduced reserves, lacked support, and were reversed in the following year. The CFO states the entries were "quarter-end estimates." Which is the MOST appropriate conclusion and action?

A. Controls are effective because the entries were reversed.

B. Controls are deficient and the pattern is a serious fraud indicator; preserve evidence, escalate, and recommend investigation.

C. The auditor should accept the CFO's explanation because quarter-end estimates are common.

D. The auditor should report only the configuration weakness.

# Q300 – Answer & Explanation

**Correct Answer: B**

**Why:** Hidden entries that increase revenue, reduce reserves, lack support, and are reversed are classic earnings-management/fraud indicators. Reversal does not legitimize them.

**A wrong:** Reversal does not cure the improper recognition.

**C wrong:** Common estimates do not explain hidden, unsupported entries.

**D wrong:** Reporting only the configuration ignores the substance.

# Q301

**Question:** The CAE is evaluating the organization's ethics program. The program has a code of conduct, annual acknowledgments, and a hotline. The hotline is managed by the general counsel, who reports to the CEO; the audit committee does not receive hotline reports; and no investigations were opened last year despite three calls. Which is the MOST significant weakness?

A. The existence of a code of conduct.

B. The hotline's reporting line to the general counsel/CEO, the audit committee's lack of visibility, and no investigations of three calls.

C. The annual acknowledgments.

D. The absence of ethics training.

# Q301 – Answer & Explanation

**Correct Answer: B**

**Why:** The hotline must be independent and visible to the audit committee; three calls with no investigations suggests suppression. This is the most significant governance/ethics weakness among the options.

**A wrong:** A code is a strength.

**C wrong:** Acknowledgments are a basic strength.

**D wrong:** Training is relevant but less significant than suppressed reports.

# Q302

**Question:** An auditor is testing the organization's controls over the financial close. The same individual prepares, reviews, and posts consolidation entries and has system access to override the consolidation. Which conclusion is MOST appropriate?

A. Controls are effective because the individual is experienced.

B. Controls are deficient; incompatible duties and override access create a significant risk of undetected error/fraud.

C. Controls are effective because consolidation is routine.

D. The auditor should not assess the financial close.

# Q302 – Answer & Explanation

**Correct Answer: B**

**Why:** Combining prepare/review/post and override access is a severe segregation-of-duties and override risk.

**A wrong:** Experience is not a control.

**C wrong:** Routine processes can still be manipulated.

**D wrong:** Financial close is a core audit area.

# Q303

**Question:** The CAE is evaluating the organization's risk appetite for cybersecurity. The board stated "zero tolerance for data breaches," but management has not funded basic security controls and has accepted known vulnerabilities. Which conclusion is MOST appropriate?

A. Risk appetite and behavior are aligned because the board stated zero tolerance.

B. There is a disconnect between stated risk appetite and actual behavior; the organization is not resourcing controls consistent with its appetite.

C. Cybersecurity risk is not a governance issue.

D. The auditor should ignore the disconnect.

# Q303 – Answer & Explanation

**Correct Answer: B**

**Why:** Risk appetite must be supported by resources and actions. A stated zero tolerance without funding/controls indicates misalignment and a weak risk culture.

**A wrong:** Statements without action are not alignment.

**C wrong:** Cybersecurity is a governance risk.

**D wrong:** Misalignment is a reportable governance weakness.

# Q304

**Question:** An auditor is testing related-party transactions. The CEO's spouse owns a consulting firm that received $3 million in contracts; the transactions were not disclosed to the board or in the financial statements. Which conclusion is MOST appropriate?

A. The transactions are acceptable because the firm is competitive.

B. The transactions represent a significant control and disclosure deficiency; related-party transactions must be identified, approved, and disclosed.

C. Related-party transactions are outside the scope of internal audit.

D. The auditor should ignore the transactions because they involve a spouse.

# Q304 – Answer & Explanation

**Correct Answer: B**

**Why:** Related-party transactions require identification, independent approval, and disclosure. Undisclosed transactions with the CEO's spouse's firm are a significant governance/control failure.

**A wrong:** Competitiveness does not eliminate disclosure requirements.

**C wrong:** Related-party transactions are a core audit area.

**D wrong:** Spousal relationships can be fraud indicators.

# Q305

**Question:** The CAE is evaluating cybersecurity governance. The organization has no board-level cybersecurity expertise, no regular cybersecurity reporting to the board, and no incident response plan. Which conclusion is MOST appropriate?

A. Cybersecurity governance is adequate because IT handles security.

B. Cybersecurity governance is deficient; board oversight, regular reporting, and an incident response plan are essential.

C. Cybersecurity is purely an IT issue, not a governance issue.

D. The auditor should not assess cybersecurity.

# Q305 – Answer & Explanation

**Correct Answer: B**

**Why:** Cybersecurity is a board-level governance risk. Lack of expertise, reporting, and an incident response plan are significant governance deficiencies.

**A wrong:** Security is not solely an IT issue; governance oversight is required.

**C wrong:** Cybersecurity is a governance and enterprise risk.

**D wrong:** Internal audit assesses cybersecurity governance.

# Q306

**Question:** An auditor is evaluating the organization's fraud risk assessment. Management's assessment is based solely on a brainstorming session with the CFO and controller, with no input from operations, sales, or IT, and no consideration of industry-specific fraud schemes. Which conclusion is MOST appropriate?

A. The fraud risk assessment is adequate because senior finance staff participated.

B. The fraud risk assessment is deficient; it lacks cross-functional input and industry-specific fraud schemes.

C. The fraud risk assessment is adequate because brainstorming is a recognized technique.

D. Fraud risk assessment is not an internal audit concern.

# Q306 – Answer & Explanation

**Correct Answer: B**

**Why:** Effective fraud risk assessment requires cross-functional input and consideration of industry-specific schemes. A finance-only brainstorm is insufficient.

**A wrong:** Finance-only input is too narrow.

**C wrong:** Brainstorming is useful but must be broad and informed.

**D wrong:** Internal audit assesses fraud risk (Standard 1210.A2).

# Q307

**Question:** The CAE is assessing the organization's internal control framework. The organization has a strong control environment and strong control activities but no monitoring activities and no information/communication process. Which conclusion is MOST appropriate?

A. The internal control framework is effective because the control environment and activities are strong.

B. The internal control framework is incomplete; all five COSO components (including monitoring and information/communication) are necessary.

C. Monitoring and information/communication are optional.

D. Only control activities matter.

# Q307 – Answer & Explanation

**Correct Answer: B**

**Why:** COSO requires all five components: control environment, risk assessment, control activities, information/communication, and monitoring. Missing components make the framework incomplete.

**A wrong:** Two components do not make a complete framework.

**C wrong:** All components are required.

**D wrong:** Control activities alone are insufficient.

# Q308

**Question:** An auditor is testing controls over the purchase of consulting services. The same manager selects the consultant, negotiates the contract, approves the invoice, and confirms receipt of services, with no independent review. Which conclusion is MOST appropriate?

A. Controls are effective because the manager is accountable for results.

B. Controls are deficient; the manager has incompatible duties (selection, negotiation, approval, receipt) with no independent review.

C. Controls are effective because consulting services are intangible.

D. The auditor should not assess consulting purchases.

# Q308 – Answer & Explanation

**Correct Answer: B**

**Why:** Combining selection, negotiation, approval, and receipt of services creates a significant segregation-of-duties weakness and fraud risk.

**A wrong:** Accountability is not a control.

**C wrong:** Intangibility does not reduce the need for controls.

**D wrong:** Consulting purchases are a legitimate audit area.

# Q309

**Question:** The CAE is evaluating the organization's risk response to a significant cybersecurity risk. Management purchased cyber insurance but has not implemented basic security controls (patching, access management, monitoring). Which conclusion is MOST appropriate?

A. The risk response is adequate because insurance transfers the risk.

B. The risk response is inadequate; insurance transfers financial impact but does not reduce the likelihood of a breach, and basic controls are missing.

C. Insurance eliminates the need for controls.

D. Cybersecurity risk is not an internal audit concern.

# Q309 – Answer & Explanation

**Correct Answer: B**

**Why:** Insurance is a risk-sharing response, not a substitute for preventive/detective controls. Basic security controls are essential to reduce likelihood.

**A wrong:** Insurance does not prevent breaches.

**C wrong:** Insurance does not eliminate the need for controls.

**D wrong:** Cybersecurity is a core internal audit area.

# Q310

**Question:** An auditor is assessing the organization's whistleblower hotline. The hotline is outsourced to an independent provider, reports go directly to the audit committee, and the audit committee reviews all reports. However, no reports have been filed in two years, and employee surveys indicate fear of retaliation. Which conclusion is MOST appropriate?

A. The hotline is effective because it is independent and reports to the audit committee.

B. The hotline may be underutilized due to fear of retaliation; the organization should address the retaliation risk and promote the hotline.

C. Zero reports prove the organization is ethical.

D. The auditor should ignore employee surveys.

# Q310 – Answer & Explanation

**Correct Answer: B**

**Why:** A hotline's effectiveness depends on trust and non-retaliation. Zero reports combined with fear of retaliation suggests underutilization and a culture problem.

**A wrong:** Structure alone is insufficient.

**C wrong:** Zero reports may indicate fear, not ethics.

**D wrong:** Surveys provide relevant culture evidence.

# Q311

**Question:** The CAE is asked to evaluate whether the organization's board has effective oversight of risk. The board receives a quarterly risk report prepared by management that contains only risk status ("green") with no details on emerging risks or risk appetite breaches. Which conclusion is MOST appropriate?

A. Board risk oversight is effective because the board receives a quarterly report.

B. Board risk oversight is likely ineffective; the report lacks detail, emerging risks, and appetite breach information.

C. Risk reporting is management's responsibility, not the board's.

D. The auditor should not assess board risk oversight.

# Q311 – Answer & Explanation

**Correct Answer: B**

**Why:** Effective board risk oversight requires transparent, detailed reporting on emerging risks and appetite breaches. A "green-only" summary impairs oversight.

**A wrong:** Receiving a report is not the same as effective oversight.

**C wrong:** The board is responsible for oversight.

**D wrong:** Internal audit assesses governance/risk oversight.

# Q312

**Question:** An auditor is testing controls over the sales commission process. Sales managers can adjust commission rates and approve their own adjustments, with no independent review. Which conclusion is MOST appropriate?

A. Controls are effective because sales managers understand commissions.

B. Controls are deficient; sales managers can adjust rates and approve their own changes, creating a significant fraud risk.

C. Controls are effective because commission adjustments are rare.

D. The auditor should not assess sales commissions.

# Q312 – Answer & Explanation

**Correct Answer: B**

**Why:** The ability to adjust rates and self-approve creates a significant fraud risk (self-dealing). Independent review is required.

**A wrong:** Knowledge is not a control.

**C wrong:** Rarity does not reduce the fraud risk.

**D wrong:** Commissions are a core audit area.

# Q313

**Question:** The CAE is evaluating the organization's compliance with its code of conduct. Senior executives routinely accept expensive gifts from vendors, and no one has been disciplined. Which conclusion is MOST appropriate?

A. The code of conduct is effective because it is written.

B. The code of conduct is not effective; senior executive behavior and lack of enforcement undermine the code.

C. Gifts are acceptable if they are expensive.

D. The auditor should ignore executive behavior.

# Q313 – Answer & Explanation

**Correct Answer: B**

**Why:** Tone at the top and enforcement are essential. Senior executives accepting gifts without consequences undermine the code's effectiveness.

**A wrong:** A written code without enforcement is ineffective.

**C wrong:** Expensive gifts create significant conflicts.

**D wrong:** Executive behavior is a key governance indicator.

# Q314

**Question:** An auditor is assessing controls over spreadsheets in financial reporting. A critical revenue calculation is performed in a spreadsheet with no version control, no formula documentation, and no independent review. Which conclusion is MOST appropriate?

A. Controls are adequate because spreadsheets are common tools.

B. Controls are deficient; critical spreadsheets require version control, documentation, and independent review.

C. Spreadsheets are always inappropriate for financial reporting.

D. The auditor should not assess spreadsheet controls.

# Q314 – Answer & Explanation

**Correct Answer: B**

**Why:** Critical spreadsheets are high-risk end-user computing tools requiring version control, documentation, and review to prevent errors/fraud.

**A wrong:** Common use does not reduce risk.

**C wrong:** Spreadsheets can be used with adequate controls.

**D wrong:** Spreadsheet controls are a valid audit area.

# Q315

**Question:** The CAE is evaluating risk management for a major IT system implementation. The project has no risk register, no steering committee, and no independent oversight; the project manager reports only to the CIO. Which conclusion is MOST appropriate?

A. Project risk management is adequate because the CIO is accountable.

B. Project risk management is deficient; major IT projects require a risk register, steering committee, and independent oversight.

C. IT projects do not require risk management.

D. The auditor should not assess IT project risk.

# Q315 – Answer & Explanation

**Correct Answer: B**

**Why:** Major IT projects require structured risk management, governance (steering committee), and independent oversight to manage cost, schedule, and risk.

**A wrong:** CIO accountability alone is insufficient.

**C wrong:** All projects require risk management.

**D wrong:** IT project risk is a core audit area.

# Q316

**Question:** An auditor is testing controls over journal entries. Twenty large manual entries were posted at year-end by the controller with descriptions such as “reclass” and “true-up,” and supporting documentation cannot be located. Which action is MOST appropriate?

A. Accept the entries because the controller is authorized.

B. Investigate the entries, request support, and report the lack of documentation as a significant deficiency.

C. Delete the entries from the system.

D. Ignore the entries because they are year-end adjustments.

# Q316 – Answer & Explanation

**Correct Answer: B**

**Why:** Large manual year-end entries by senior management are a high fraud risk area. Lack of support is a significant deficiency requiring investigation and reporting.

**A wrong:** Authorization does not eliminate the need for support.

**C wrong:** Internal audit should not alter records.

**D wrong:** Year-end adjustments require documentation.

# Q317

**Question:** The CAE is evaluating the organization's use of key risk indicators (KRIs). The organization tracks revenue, profit, and customer satisfaction but has no KRIs for compliance, cybersecurity, or supply chain risk. Which conclusion is MOST appropriate?

A. KRI coverage is adequate because financial and customer metrics are tracked.

B. KRI coverage is incomplete; the organization lacks KRIs for significant risk areas (compliance, cybersecurity, supply chain).

C. KRIs are optional for all organizations.

D. The auditor should not assess KRIs.

# Q317 – Answer & Explanation

**Correct Answer: B**

**Why:** KRIs should cover the organization's significant risks. Omitting compliance, cybersecurity, and supply chain KRIs leaves key risks unmonitored.

**A wrong:** Financial/customer metrics alone are insufficient.

**C wrong:** KRIs are an important monitoring tool.

**D wrong:** Internal audit assesses risk monitoring.

# Q318

**Question:** An auditor is evaluating controls over the financial close. The same individual prepares, reviews, and posts consolidation entries and has system access to override the consolidation. Which conclusion is MOST appropriate?

A. Controls are effective because the individual is experienced.

B. Controls are deficient; incompatible duties and override access create a significant risk of undetected error/fraud.

C. Controls are effective because consolidation is routine.

D. The auditor should not assess the financial close.

# Q318 – Answer & Explanation

**Correct Answer: B**

**Why:** Combining prepare/review/post and override access is a severe segregation-of-duties and override risk.

**A wrong:** Experience is not a control.

**C wrong:** Routine processes can still be manipulated.

**D wrong:** Financial close is a core audit area.

# Q319

**Question:** The CAE is evaluating the organization's risk appetite for cybersecurity. The board stated "zero tolerance for data breaches," but management has not funded basic security controls and has accepted known vulnerabilities. Which conclusion is MOST appropriate?

A. Risk appetite and behavior are aligned because the board stated zero tolerance.

B. There is a disconnect between stated risk appetite and actual behavior; the organization is not resourcing controls consistent with its appetite.

C. Cybersecurity risk is not a governance issue.

D. The auditor should ignore the disconnect.

# Q319 – Answer & Explanation

**Correct Answer: B**

**Why:** Risk appetite must be supported by resources and actions. A stated zero tolerance without funding/controls indicates misalignment and a weak risk culture.

**A wrong:** Statements without action are not alignment.

**C wrong:** Cybersecurity is a governance risk.

**D wrong:** Misalignment is a reportable governance weakness.

# Q320

**Question:** An auditor is testing controls over the use of artificial intelligence (AI) in credit decisions. The AI model was developed by an external vendor, has not been validated, and management cannot explain the model's logic. Which conclusion is MOST appropriate?

A. Controls are adequate because the model was developed by a vendor.

B. Controls are deficient; unvalidated AI models with unexplainable logic create significant model, compliance, and reputational risk.

C. AI models do not require validation.

D. The auditor should not assess AI models.

# Q320 – Answer & Explanation

**Correct Answer: B**

**Why:** AI models used in credit decisions require validation, documentation, and explainability to manage model risk and regulatory compliance.

**A wrong:** Vendor development does not eliminate the need for validation.

**C wrong:** AI models require validation.

**D wrong:** AI risk is a core internal audit area.

# Q321

**Question:** The CAE is evaluating the organization's fraud hotline. The hotline is managed by the internal audit function, reports go directly to the CAE, and the CAE investigates all reports. Which statement is MOST accurate?

A. The hotline is effective because internal audit is independent.

B. The hotline may create an independence/self-review issue if internal audit investigates reports about its own function; oversight by the audit committee is important.

C. The hotline is ineffective because internal audit manages it.

D. Hotlines should never be managed by internal audit.

# Q321 – Answer & Explanation

**Correct Answer: B**

**Why:** Internal audit managing a hotline is common, but reports involving internal audit itself create a self-review threat. Audit committee oversight and escalation protocols are important safeguards.

**A wrong:** Independence alone does not resolve self-review for reports about internal audit.

**C wrong:** Internal audit management is not inherently ineffective.

**D wrong:** Internal audit can manage hotlines with safeguards.

# Q322

**Question:** An auditor is testing controls over the financial close. The controller prepares, reviews, and posts consolidation entries and has system access to override the consolidation. Which conclusion is MOST appropriate?

A. Controls are effective because the controller is experienced.

B. Controls are deficient; incompatible duties and override access create a significant risk of undetected error/fraud.

C. Controls are effective because consolidation is routine.

D. The auditor should not assess the financial close.

# Q322 – Answer & Explanation

**Correct Answer: B**

**Why:** Combining prepare/review/post and override access is a severe segregation-of-duties and override risk.

**A wrong:** Experience is not a control.

**C wrong:** Routine processes can still be manipulated.

**D wrong:** Financial close is a core audit area.

# Q323

**Question:** The CAE is evaluating the organization's risk appetite for cybersecurity. The board stated "zero tolerance for data breaches," but management has not funded basic security controls and has accepted known vulnerabilities. Which conclusion is MOST appropriate?

A. Risk appetite and behavior are aligned because the board stated zero tolerance.

B. There is a disconnect between stated risk appetite and actual behavior; the organization is not resourcing controls consistent with its appetite.

C. Cybersecurity risk is not a governance issue.

D. The auditor should ignore the disconnect.

# Q323 – Answer & Explanation

**Correct Answer: B**

**Why:** Risk appetite must be supported by resources and actions. A stated zero tolerance without funding/controls indicates misalignment and a weak risk culture.

**A wrong:** Statements without action are not alignment.

**C wrong:** Cybersecurity is a governance risk.

**D wrong:** Misalignment is a reportable governance weakness.

# Q324

**Question:** An auditor is testing related-party transactions. The CEO's spouse owns a consulting firm that received $3 million in contracts; the transactions were not disclosed to the board or in the financial statements. Which conclusion is MOST appropriate?

A. The transactions are acceptable because the firm is competitive.

B. The transactions represent a significant control and disclosure deficiency; related-party transactions must be identified, approved, and disclosed.

C. Related-party transactions are outside the scope of internal audit.

D. The auditor should ignore the transactions because they involve a spouse.

# Q324 – Answer & Explanation

**Correct Answer: B**

**Why:** Related-party transactions require identification, independent approval, and disclosure. Undisclosed transactions with the CEO's spouse's firm are a significant governance/control failure.

**A wrong:** Competitiveness does not eliminate disclosure requirements.

**C wrong:** Related-party transactions are a core audit area.

**D wrong:** Spousal relationships can be fraud indicators.

# Q325

**Question:** The CAE is evaluating cybersecurity governance. The organization has no board-level cybersecurity expertise, no regular cybersecurity reporting to the board, and no incident response plan. Which conclusion is MOST appropriate?

A. Cybersecurity governance is adequate because IT handles security.

B. Cybersecurity governance is deficient; board oversight, regular reporting, and an incident response plan are essential.

C. Cybersecurity is purely an IT issue, not a governance issue.

D. The auditor should not assess cybersecurity.

# Q325 – Answer & Explanation

**Correct Answer: B**

**Why:** Cybersecurity is a board-level governance risk. Lack of expertise, reporting, and an incident response plan are significant governance deficiencies.

**A wrong:** Security is not solely an IT issue; governance oversight is required.

**C wrong:** Cybersecurity is a governance and enterprise risk.

**D wrong:** Internal audit assesses cybersecurity governance.

# Q326

**Question:** An auditor is evaluating the organization's fraud risk assessment. Management's assessment is based solely on a brainstorming session with the CFO and controller, with no input from operations, sales, or IT, and no consideration of industry-specific fraud schemes. Which conclusion is MOST appropriate?

A. The fraud risk assessment is adequate because senior finance staff participated.

B. The fraud risk assessment is deficient; it lacks cross-functional input and industry-specific fraud schemes.

C. The fraud risk assessment is adequate because brainstorming is a recognized technique.

D. Fraud risk assessment is not an internal audit concern.

# Q326 – Answer & Explanation

**Correct Answer: B**

**Why:** Effective fraud risk assessment requires cross-functional input and consideration of industry-specific schemes. A finance-only brainstorm is insufficient.

**A wrong:** Finance-only input is too narrow.

**C wrong:** Brainstorming is useful but must be broad and informed.

**D wrong:** Internal audit assesses fraud risk (Standard 1210.A2).

# Q327

**Question:** The CAE is assessing the organization's internal control framework. The organization has a strong control environment and strong control activities but no monitoring activities and no information/communication process. Which conclusion is MOST appropriate?

A. The internal control framework is effective because the control environment and activities are strong.

B. The internal control framework is incomplete; all five COSO components (including monitoring and information/communication) are necessary.

C. Monitoring and information/communication are optional.

D. Only control activities matter.

# Q327 – Answer & Explanation

**Correct Answer: B**

**Why:** COSO requires all five components: control environment, risk assessment, control activities, information/communication, and monitoring. Missing components make the framework incomplete.

**A wrong:** Two components do not make a complete framework.

**C wrong:** All components are required.

**D wrong:** Control activities alone are insufficient.

# Q328

**Question:** An auditor is testing controls over the purchase of consulting services. The same manager selects the consultant, negotiates the contract, approves the invoice, and confirms receipt of services, with no independent review. Which conclusion is MOST appropriate?

A. Controls are effective because the manager is accountable for results.

B. Controls are deficient; the manager has incompatible duties (selection, negotiation, approval, receipt) with no independent review.

C. Controls are effective because consulting services are intangible.

D. The auditor should not assess consulting purchases.

# Q328 – Answer & Explanation

**Correct Answer: B**

**Why:** Combining selection, negotiation, approval, and receipt of services creates a significant segregation-of-duties weakness and fraud risk.

**A wrong:** Accountability is not a control.

**C wrong:** Intangibility does not reduce the need for controls.

**D wrong:** Consulting purchases are a legitimate audit area.

# Q329

**Question:** The CAE is evaluating the organization's risk response to a significant cybersecurity risk. Management purchased cyber insurance but has not implemented basic security controls (patching, access management, monitoring). Which conclusion is MOST appropriate?

A. The risk response is adequate because insurance transfers the risk.

B. The risk response is inadequate; insurance transfers financial impact but does not reduce the likelihood of a breach, and basic controls are missing.

C. Insurance eliminates the need for controls.

D. Cybersecurity risk is not an internal audit concern.

# Q329 – Answer & Explanation

**Correct Answer: B**

**Why:** Insurance is a risk-sharing response, not a substitute for preventive/detective controls. Basic security controls are essential to reduce likelihood.

**A wrong:** Insurance does not prevent breaches.

**C wrong:** Insurance does not eliminate the need for controls.

**D wrong:** Cybersecurity is a core internal audit area.

# Q330

**Question:** An auditor is assessing the organization's whistleblower hotline. The hotline is outsourced to an independent provider, reports go directly to the audit committee, and the audit committee reviews all reports. However, no reports have been filed in two years, and employee surveys indicate fear of retaliation. Which conclusion is MOST appropriate?

A. The hotline is effective because it is independent and reports to the audit committee.

B. The hotline may be underutilized due to fear of retaliation; the organization should address the retaliation risk and promote the hotline.

C. Zero reports prove the organization is ethical.

D. The auditor should ignore employee surveys.

# Q330 – Answer & Explanation

**Correct Answer: B**

**Why:** A hotline's effectiveness depends on trust and non-retaliation. Zero reports combined with fear of retaliation suggests underutilization and a culture problem.

**A wrong:** Structure alone is insufficient.

**C wrong:** Zero reports may indicate fear, not ethics.

**D wrong:** Surveys provide relevant culture evidence.

# Q331

**Question:** The CAE is asked to evaluate whether the organization's board has effective oversight of risk. The board receives a quarterly risk report prepared by management that contains only risk status ("green") with no details on emerging risks or risk appetite breaches. Which conclusion is MOST appropriate?

A. Board risk oversight is effective because the board receives a quarterly report.

B. Board risk oversight is likely ineffective; the report lacks detail, emerging risks, and appetite breach information.

C. Risk reporting is management's responsibility, not the board's.

D. The auditor should not assess board risk oversight.

# Q331 – Answer & Explanation

**Correct Answer: B**

**Why:** Effective board risk oversight requires transparent, detailed reporting on emerging risks and appetite breaches. A "green-only" summary impairs oversight.

**A wrong:** Receiving a report is not the same as effective oversight.

**C wrong:** The board is responsible for oversight.

**D wrong:** Internal audit assesses governance/risk oversight.

# Q332

**Question:** An auditor is testing controls over the sales commission process. Sales managers can adjust commission rates and approve their own adjustments, with no independent review. Which conclusion is MOST appropriate?

A. Controls are effective because sales managers understand commissions.

B. Controls are deficient; sales managers can adjust rates and approve their own changes, creating a significant fraud risk.

C. Controls are effective because commission adjustments are rare.

D. The auditor should not assess sales commissions.

# Q332 – Answer & Explanation

**Correct Answer: B**

**Why:** The ability to adjust rates and self-approve creates a significant fraud risk (self-dealing). Independent review is required.

**A wrong:** Knowledge is not a control.

**C wrong:** Rarity does not reduce the fraud risk.

**D wrong:** Commissions are a core audit area.

# Q333

**Question:** The CAE is evaluating the organization's compliance with its code of conduct. Senior executives routinely accept expensive gifts from vendors, and no one has been disciplined. Which conclusion is MOST appropriate?

A. The code of conduct is effective because it is written.

B. The code of conduct is not effective; senior executive behavior and lack of enforcement undermine the code.

C. Gifts are acceptable if they are expensive.

D. The auditor should ignore executive behavior.

# Q333 – Answer & Explanation

**Correct Answer: B**

**Why:** Tone at the top and enforcement are essential. Senior executives accepting gifts without consequences undermine the code's effectiveness.

**A wrong:** A written code without enforcement is ineffective.

**C wrong:** Expensive gifts create significant conflicts.

**D wrong:** Executive behavior is a key governance indicator.

# Q334

**Question:** An auditor is assessing controls over spreadsheets in financial reporting. A critical revenue calculation is performed in a spreadsheet with no version control, no formula documentation, and no independent review. Which conclusion is MOST appropriate?

A. Controls are adequate because spreadsheets are common tools.

B. Controls are deficient; critical spreadsheets require version control, documentation, and independent review.

C. Spreadsheets are always inappropriate for financial reporting.

D. The auditor should not assess spreadsheet controls.

# Q334 – Answer & Explanation

**Correct Answer: B**

**Why:** Critical spreadsheets are high-risk end-user computing tools requiring version control, documentation, and review to prevent errors/fraud.

**A wrong:** Common use does not reduce risk.

**C wrong:** Spreadsheets can be used with adequate controls.

**D wrong:** Spreadsheet controls are a valid audit area.

# Q335

**Question:** The CAE is evaluating risk management for a major IT system implementation. The project has no risk register, no steering committee, and no independent oversight; the project manager reports only to the CIO. Which conclusion is MOST appropriate?

A. Project risk management is adequate because the CIO is accountable.

B. Project risk management is deficient; major IT projects require a risk register, steering committee, and independent oversight.

C. IT projects do not require risk management.

D. The auditor should not assess IT project risk.

# Q335 – Answer & Explanation

**Correct Answer: B**

**Why:** Major IT projects require structured risk management, governance (steering committee), and independent oversight to manage cost, schedule, and risk.

**A wrong:** CIO accountability alone is insufficient.

**C wrong:** All projects require risk management.

**D wrong:** IT project risk is a core audit area.

# Q336

**Question:** An auditor is testing controls over journal entries. Twenty large manual entries were posted at year-end by the controller with descriptions such as “reclass” and “true-up,” and supporting documentation cannot be located. Which action is MOST appropriate?

A. Accept the entries because the controller is authorized.

B. Investigate the entries, request support, and report the lack of documentation as a significant deficiency.

C. Delete the entries from the system.

D. Ignore the entries because they are year-end adjustments.

# Q336 – Answer & Explanation

**Correct Answer: B**

**Why:** Large manual year-end entries by senior management are a high fraud risk area. Lack of support is a significant deficiency requiring investigation and reporting.

**A wrong:** Authorization does not eliminate the need for support.

**C wrong:** Internal audit should not alter records.

**D wrong:** Year-end adjustments require documentation.

# Q337

**Question:** The CAE is evaluating the organization's use of key risk indicators (KRIs). The organization tracks revenue, profit, and customer satisfaction but has no KRIs for compliance, cybersecurity, or supply chain risk. Which conclusion is MOST appropriate?

A. KRI coverage is adequate because financial and customer metrics are tracked.

B. KRI coverage is incomplete; the organization lacks KRIs for significant risk areas (compliance, cybersecurity, supply chain).

C. KRIs are optional for all organizations.

D. The auditor should not assess KRIs.

# Q337 – Answer & Explanation

**Correct Answer: B**

**Why:** KRIs should cover the organization's significant risks. Omitting compliance, cybersecurity, and supply chain KRIs leaves key risks unmonitored.

**A wrong:** Financial/customer metrics alone are insufficient.

**C wrong:** KRIs are an important monitoring tool.

**D wrong:** Internal audit assesses risk monitoring.

# Q338

**Question:** An auditor is evaluating controls over the financial close. The same individual prepares, reviews, and posts consolidation entries and has system access to override the consolidation. Which conclusion is MOST appropriate?

A. Controls are effective because the individual is experienced.

B. Controls are deficient; incompatible duties and override access create a significant risk of undetected error/fraud.

C. Controls are effective because consolidation is routine.

D. The auditor should not assess the financial close.

# Q338 – Answer & Explanation

**Correct Answer: B**

**Why:** Combining prepare/review/post and override access is a severe segregation-of-duties and override risk.

**A wrong:** Experience is not a control.

**C wrong:** Routine processes can still be manipulated.

**D wrong:** Financial close is a core audit area.

# Q339

**Question:** The CAE is evaluating the organization's risk appetite for cybersecurity. The board stated "zero tolerance for data breaches," but management has not funded basic security controls and has accepted known vulnerabilities. Which conclusion is MOST appropriate?

A. Risk appetite and behavior are aligned because the board stated zero tolerance.

B. There is a disconnect between stated risk appetite and actual behavior; the organization is not resourcing controls consistent with its appetite.

C. Cybersecurity risk is not a governance issue.

D. The auditor should ignore the disconnect.

# Q339 – Answer & Explanation

**Correct Answer: B**

**Why:** Risk appetite must be supported by resources and actions. A stated zero tolerance without funding/controls indicates misalignment and a weak risk culture.

**A wrong:** Statements without action are not alignment.

**C wrong:** Cybersecurity is a governance risk.

**D wrong:** Misalignment is a reportable governance weakness.

# Q340

**Question:** An auditor is testing controls over the use of artificial intelligence (AI) in credit decisions. The AI model was developed by an external vendor, has not been validated, and management cannot explain the model's logic. Which conclusion is MOST appropriate?

A. Controls are adequate because the model was developed by a vendor.

B. Controls are deficient; unvalidated AI models with unexplainable logic create significant model, compliance, and reputational risk.

C. AI models do not require validation.

D. The auditor should not assess AI models.

# Q340 – Answer & Explanation

**Correct Answer: B**

**Why:** AI models used in credit decisions require validation, documentation, and explainability to manage model risk and regulatory compliance.

**A wrong:** Vendor development does not eliminate the need for validation.

**C wrong:** AI models require validation.

**D wrong:** AI risk is a core internal audit area.

# Q341

**Question:** The CAE is evaluating the organization's fraud hotline. The hotline is managed by the internal audit function, reports go directly to the CAE, and the CAE investigates all reports. Which statement is MOST accurate?

A. The hotline is effective because internal audit is independent.

B. The hotline may create an independence/self-review issue if internal audit investigates reports about its own function; oversight by the audit committee is important.

C. The hotline is ineffective because internal audit manages it.

D. Hotlines should never be managed by internal audit.

# Q341 – Answer & Explanation

**Correct Answer: B**

**Why:** Internal audit managing a hotline is common, but reports involving internal audit itself create a self-review threat. Audit committee oversight and escalation protocols are important safeguards.

**A wrong:** Independence alone does not resolve self-review for reports about internal audit.

**C wrong:** Internal audit management is not inherently ineffective.

**D wrong:** Internal audit can manage hotlines with safeguards.

# Q342

**Question:** An auditor is testing controls over the financial close. The controller prepares, reviews, and posts consolidation entries and has system access to override the consolidation. Which conclusion is MOST appropriate?

A. Controls are effective because the controller is experienced.

B. Controls are deficient; incompatible duties and override access create a significant risk of undetected error/fraud.

C. Controls are effective because consolidation is routine.

D. The auditor should not assess the financial close.

# Q342 – Answer & Explanation

**Correct Answer: B**

**Why:** Combining prepare/review/post and override access is a severe segregation-of-duties and override risk.

**A wrong:** Experience is not a control.

**C wrong:** Routine processes can still be manipulated.

**D wrong:** Financial close is a core audit area.

# Q343

**Question:** The CAE is evaluating the organization's risk appetite for cybersecurity. The board stated "zero tolerance for data breaches," but management has not funded basic security controls and has accepted known vulnerabilities. Which conclusion is MOST appropriate?

A. Risk appetite and behavior are aligned because the board stated zero tolerance.

B. There is a disconnect between stated risk appetite and actual behavior; the organization is not resourcing controls consistent with its appetite.

C. Cybersecurity risk is not a governance issue.

D. The auditor should ignore the disconnect.

# Q343 – Answer & Explanation

**Correct Answer: B**

**Why:** Risk appetite must be supported by resources and actions. A stated zero tolerance without funding/controls indicates misalignment and a weak risk culture.

**A wrong:** Statements without action are not alignment.

**C wrong:** Cybersecurity is a governance risk.

**D wrong:** Misalignment is a reportable governance weakness.

# Q344

**Question:** An auditor is testing related-party transactions. The CEO's spouse owns a consulting firm that received $3 million in contracts; the transactions were not disclosed to the board or in the financial statements. Which conclusion is MOST appropriate?

A. The transactions are acceptable because the firm is competitive.

B. The transactions represent a significant control and disclosure deficiency; related-party transactions must be identified, approved, and disclosed.

C. Related-party transactions are outside the scope of internal audit.

D. The auditor should ignore the transactions because they involve a spouse.

# Q344 – Answer & Explanation

**Correct Answer: B**

**Why:** Related-party transactions require identification, independent approval, and disclosure. Undisclosed transactions with the CEO's spouse's firm are a significant governance/control failure.

**A wrong:** Competitiveness does not eliminate disclosure requirements.

**C wrong:** Related-party transactions are a core audit area.

**D wrong:** Spousal relationships can be fraud indicators.

# Q345

**Question:** The CAE is evaluating cybersecurity governance. The organization has no board-level cybersecurity expertise, no regular cybersecurity reporting to the board, and no incident response plan. Which conclusion is MOST appropriate?

A. Cybersecurity governance is adequate because IT handles security.

B. Cybersecurity governance is deficient; board oversight, regular reporting, and an incident response plan are essential.

C. Cybersecurity is purely an IT issue, not a governance issue.

D. The auditor should not assess cybersecurity.

# Q345 – Answer & Explanation

**Correct Answer: B**

**Why:** Cybersecurity is a board-level governance risk. Lack of expertise, reporting, and an incident response plan are significant governance deficiencies.

**A wrong:** Security is not solely an IT issue; governance oversight is required.

**C wrong:** Cybersecurity is a governance and enterprise risk.

**D wrong:** Internal audit assesses cybersecurity governance.

# Q346

**Question:** An auditor is evaluating the organization's fraud risk assessment. Management's assessment is based solely on a brainstorming session with the CFO and controller, with no input from operations, sales, or IT, and no consideration of industry-specific fraud schemes. Which conclusion is MOST appropriate?

A. The fraud risk assessment is adequate because senior finance staff participated.

B. The fraud risk assessment is deficient; it lacks cross-functional input and industry-specific fraud schemes.

C. The fraud risk assessment is adequate because brainstorming is a recognized technique.

D. Fraud risk assessment is not an internal audit concern.

# Q346 – Answer & Explanation

**Correct Answer: B**

**Why:** Effective fraud risk assessment requires cross-functional input and consideration of industry-specific schemes. A finance-only brainstorm is insufficient.

**A wrong:** Finance-only input is too narrow.

**C wrong:** Brainstorming is useful but must be broad and informed.

**D wrong:** Internal audit assesses fraud risk (Standard 1210.A2).

# Q347

**Question:** The CAE is assessing the organization's internal control framework. The organization has a strong control environment and strong control activities but no monitoring activities and no information/communication process. Which conclusion is MOST appropriate?

A. The internal control framework is effective because the control environment and activities are strong.

B. The internal control framework is incomplete; all five COSO components (including monitoring and information/communication) are necessary.

C. Monitoring and information/communication are optional.

D. Only control activities matter.

# Q347 – Answer & Explanation

**Correct Answer: B**

**Why:** COSO requires all five components: control environment, risk assessment, control activities, information/communication, and monitoring. Missing components make the framework incomplete.

**A wrong:** Two components do not make a complete framework.

**C wrong:** All components are required.

**D wrong:** Control activities alone are insufficient.

# Q348

**Question:** An auditor is testing controls over the purchase of consulting services. The same manager selects the consultant, negotiates the contract, approves the invoice, and confirms receipt of services, with no independent review. Which conclusion is MOST appropriate?

A. Controls are effective because the manager is accountable for results.

B. Controls are deficient; the manager has incompatible duties (selection, negotiation, approval, receipt) with no independent review.

C. Controls are effective because consulting services are intangible.

D. The auditor should not assess consulting purchases.

# Q348 – Answer & Explanation

**Correct Answer: B**

**Why:** Combining selection, negotiation, approval, and receipt of services creates a significant segregation-of-duties weakness and fraud risk.

**A wrong:** Accountability is not a control.

**C wrong:** Intangibility does not reduce the need for controls.

**D wrong:** Consulting purchases are a legitimate audit area.

# Q349

**Question:** The CAE is evaluating the organization's risk response to a significant cybersecurity risk. Management purchased cyber insurance but has not implemented basic security controls (patching, access management, monitoring). Which conclusion is MOST appropriate?

A. The risk response is adequate because insurance transfers the risk.

B. The risk response is inadequate; insurance transfers financial impact but does not reduce the likelihood of a breach, and basic controls are missing.

C. Insurance eliminates the need for controls.

D. Cybersecurity risk is not an internal audit concern.

# Q349 – Answer & Explanation

**Correct Answer: B**

**Why:** Insurance is a risk-sharing response, not a substitute for preventive/detective controls. Basic security controls are essential to reduce likelihood.

**A wrong:** Insurance does not prevent breaches.

**C wrong:** Insurance does not eliminate the need for controls.

**D wrong:** Cybersecurity is a core internal audit area.

# Q350

**Question:** An auditor is assessing the organization's whistleblower hotline. The hotline is outsourced to an independent provider, reports go directly to the audit committee, and the audit committee reviews all reports. However, no reports have been filed in two years, and employee surveys indicate fear of retaliation. Which conclusion is MOST appropriate?

A. The hotline is effective because it is independent and reports to the audit committee.

B. The hotline may be underutilized due to fear of retaliation; the organization should address the retaliation risk and promote the hotline.

C. Zero reports prove the organization is ethical.

D. The auditor should ignore employee surveys.

# Q350 – Answer & Explanation

**Correct Answer: B**

**Why:** A hotline's effectiveness depends on trust and non-retaliation. Zero reports combined with fear of retaliation suggests underutilization and a culture problem.

**A wrong:** Structure alone is insufficient.

**C wrong:** Zero reports may indicate fear, not ethics.

**D wrong:** Surveys provide relevant culture evidence.

# Q351

**Question:** The CAE is asked to evaluate whether the organization's board has effective oversight of risk. The board receives a quarterly risk report prepared by management that contains only risk status ("green") with no details on emerging risks or risk appetite breaches. Which conclusion is MOST appropriate?

A. Board risk oversight is effective because the board receives a quarterly report.

B. Board risk oversight is likely ineffective; the report lacks detail, emerging risks, and appetite breach information.

C. Risk reporting is management's responsibility, not the board's.

D. The auditor should not assess board risk oversight.

# Q351 – Answer & Explanation

**Correct Answer: B**

**Why:** Effective board risk oversight requires transparent, detailed reporting on emerging risks and appetite breaches. A "green-only" summary impairs oversight.

**A wrong:** Receiving a report is not the same as effective oversight.

**C wrong:** The board is responsible for oversight.

**D wrong:** Internal audit assesses governance/risk oversight.

# Q352

**Question:** An auditor is testing controls over the sales commission process. Sales managers can adjust commission rates and approve their own adjustments, with no independent review. Which conclusion is MOST appropriate?

A. Controls are effective because sales managers understand commissions.

B. Controls are deficient; sales managers can adjust rates and approve their own changes, creating a significant fraud risk.

C. Controls are effective because commission adjustments are rare.

D. The auditor should not assess sales commissions.

# Q352 – Answer & Explanation

**Correct Answer: B**

**Why:** The ability to adjust rates and self-approve creates a significant fraud risk (self-dealing). Independent review is required.

**A wrong:** Knowledge is not a control.

**C wrong:** Rarity does not reduce the fraud risk.

**D wrong:** Commissions are a core audit area.

# Q353

**Question:** The CAE is evaluating the organization's compliance with its code of conduct. Senior executives routinely accept expensive gifts from vendors, and no one has been disciplined. Which conclusion is MOST appropriate?

A. The code of conduct is effective because it is written.

B. The code of conduct is not effective; senior executive behavior and lack of enforcement undermine the code.

C. Gifts are acceptable if they are expensive.

D. The auditor should ignore executive behavior.

# Q353 – Answer & Explanation

**Correct Answer: B**

**Why:** Tone at the top and enforcement are essential. Senior executives accepting gifts without consequences undermine the code's effectiveness.

**A wrong:** A written code without enforcement is ineffective.

**C wrong:** Expensive gifts create significant conflicts.

**D wrong:** Executive behavior is a key governance indicator.

# Q354

**Question:** An auditor is assessing controls over spreadsheets in financial reporting. A critical revenue calculation is performed in a spreadsheet with no version control, no formula documentation, and no independent review. Which conclusion is MOST appropriate?

A. Controls are adequate because spreadsheets are common tools.

B. Controls are deficient; critical spreadsheets require version control, documentation, and independent review.

C. Spreadsheets are always inappropriate for financial reporting.

D. The auditor should not assess spreadsheet controls.

# Q354 – Answer & Explanation

**Correct Answer: B**

**Why:** Critical spreadsheets are high-risk end-user computing tools requiring version control, documentation, and review to prevent errors/fraud.

**A wrong:** Common use does not reduce risk.

**C wrong:** Spreadsheets can be used with adequate controls.

**D wrong:** Spreadsheet controls are a valid audit area.

# End

End of Questions 296–354

Review, repeat, and mark weak areas.